

Security+ 5.2 · Business Impact Analysis

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.2** —
Business Impact Analysis (2:55) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: BIA: business impact if a critical process STOPS. MTR/MTTR (response/repair time); MTU (mean time to use); MTBF (mean time between failures). Feeds RTO/RPO.

High-Yield Core Concepts Tested on Exam

- BIA: how much the business LOSES per hour/day if a critical process stops
- MTTR: mean time to repair/respond; MTBF: mean time between failures (reliability)
- BIA identifies critical processes and their dependencies
- BIA results feed into RTO (recovery time objective) and RPO (recovery point objective)
- MTU: mean time to use — time until a system is actually used after recovery

Exam Tips & Classic Scenarios

- 'evaluates impact of losing critical process' = BIA
- 'determines how long a business can tolerate downtime' = BIA
- 'calculates financial loss per hour of outage' = BIA

Typical Exam Scenario: 'Company calculates how much it would lose per hour if e-commerce went down' = BIA.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.2 — Business Impact Analysis)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **BIA:** Business Impact Analysis: Formal risk assessment process quantifying operational and financial consequences resulting from business process interruptions.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. RTO (Recovery Time Objective) measures:

- A)** How much DATA you accept losing
- B)** How much TIME the service can be down
- C)** The cost of the incident
- D)** The number of affected users

2. If a server fails and must be operational within 4 hours according to an SLA, this defines:

- A)** RPO (Recovery Point Objective)
- B)** RTO (Recovery Time Objective)
- C)** MTTR (Mean Time To Repair)
- D)** MTBF (Mean Time Between Failures)

3. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'BIA: how much the business LOSES per hour/day if a critical process stops.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: BIA: how much the business LOSES per hour/day if a critical process stops...

4. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'MTTR: response/repair time; MTBF: reliability'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: MTTR: response/repair time; MTBF: reliability...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'evaluates impact of losing critical process'=BIA'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'evaluates impact of losing critical process'=BIA...

6. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'company calculates how much it would lose per hour if the e-commerce site went down'=BIA.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'company calculates how much it would lose per hour if the e-commerce site went down'=BIA....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'BIA: how much the business LOSES per hour/day if a critical process stops'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: BIA: how much the business LOSES per hour/day if a critical process stops...
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'MTTR: response/repair time; MTBF: reliability'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: MTTR: response/repair time; MTBF: reliability...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'evaluates impact of losing critical process' = BIA. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'evaluates impact of losing critical process' = BIA
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Business Impact Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'company calculates how much it would lose immediately if e-commerce went down' = BIA. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'company calculates how much it would lose immediately if e-commerce went down' = BIA...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — How much TIME the service can be down.

✓ **Why it's correct:** The correct answer is: how much TIME the service can be down. RTO (Recovery Time Objective) is a central metric in the Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP), covered in the Business Continuity and Disaster Recovery domain of CompTIA Security+ SY0-701. It defines the maximum acceptable time to restore a service or process after an interruption, before the business impact becomes unacceptable. For example, if an e-commerce site sets an RTO of 2 hours, the recovery team must restore operations within 2 hours after the incident. RTO guides the choice of recovery strategies (hot site, warm site, cold site), backup frequency, and investments in redundancy. It is often confused with RPO, but while RTO measures downtime, RPO measures data loss.

✗ **Why the others are wrong:**

- *How much DATA you accept losing:* This is the definition of RPO (Recovery Point Objective), not RTO. RPO establishes the maximum amount of data that can be lost, measured in time (e.g., 15 minutes of transactions). It determines backup frequency: if the RPO is 1 hour, backups must occur at least every hour. RTO, on the other hand, focuses on service restoration time, not data loss. Confusing the two concepts leads to inadequate recovery strategies, as a low RPO does not guarantee a low RTO, and vice versa.
- *The cost of the incident:* The cost of the incident is a financial metric that quantifies direct and indirect losses resulting from an interruption (lost revenue, fines, productivity, reputational damage). Although it is an input to justify investments in continuity, it is not the definition of RTO. RTO is a time goal, not a monetary value. Using cost as the definition of RTO would divert focus from recovery planning, which needs clear temporal parameters to guide technical actions.
- *The number of affected users:* The number of affected users is an impact metric, useful for prioritization and communication, but it does not define RTO. RTO is a recovery time objective, regardless of the number of users. A service critical to few users may have a short RTO, while a service for many users may have a longer RTO, depending on business criticality. Therefore, this alternative does not correspond to the formal concept of RTO.

2) B — RTO (Recovery Time Objective).

✓ **Why it's correct:** RTO (Recovery Time Objective) is the maximum acceptable time to restore a service or system after a disruption, as defined in business continuity objectives. If an SLA states that the server must be operational within 4 hours, that is exactly the RTO: the target time for recovery. CompTIA Security+ distinguishes RTO from RPO and other metrics, with RTO focusing on tolerable downtime, not data loss.

✗ **Why the others are wrong:**

- *RPO (Recovery Point Objective):* RPO (Recovery Point Objective) defines the maximum amount of data the organization can lose, measured in time (e.g., 1 hour of transactions). It relates to backup frequency and tolerance for data loss, not service recovery time. A 4-hour SLA to restore the server does not describe data loss but rather the maximum downtime, so it is not RPO.
- *MTTR (Mean Time To Repair):* MTTR (Mean Time To Repair) is a statistical metric representing the average time required to repair a component or system after a failure. It is a historical and operational measure, not a contractual objective or recovery goal. The 4-hour SLA is a prescriptive recovery target, not an average of past repairs. Confusing MTTR with RTO is a common conceptual error but technically distinct.
- *MTBF (Mean Time Between Failures):* MTBF (Mean Time Between Failures) is the average time between consecutive failures of a repairable system, indicating its reliability. It does not establish

recovery deadlines but rather the expected frequency of failures. A 4-hour SLA for restoration is unrelated to failure frequency but to recovery speed. Therefore, MTBF does not answer the given definition.

3) D — Implement the corresponding solution: BIA: how much the business LOSES per hour/day if a critical process stops....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): BIA quantifies the financial loss per hour/day when a critical business process is unavailable. This metric drives recovery time objectives (RTO) and recovery point objectives (RPO).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: MTTR: response/repair time; MTBF: reliability....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): MTTR: response/repair time; MTBF: reliability.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'evaluates impact of losing critical process'=BIA....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): 'evaluates impact of losing critical process'=BIA. A Business Impact Analysis (BIA) is a systematic process to determine and evaluate the potential effects of an interruption to critical business operations as a result of a disaster, accident, or emergency. It identifies critical business functions, dependencies, and the impact of their loss over time, helping to prioritize recovery strategies and determine recovery time objectives (RTO) and recovery point objectives (RPO). It is a key component of business continuity planning.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'company calculates how much it would lose per hour if the e-commerce site went down'=BIA.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): 'company calculates how much it would lose per hour if the e-commerce site went down'=BIA. A BIA quantifies the financial and operational impact of downtime, helping prioritize recovery objectives (RTO/RPO). The correct action is to implement the corresponding BIA process.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: BIA: how much the business LOSES per hour/day if a critical process stops....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): BIA: how much the business LOSES per hour/day if a critical process stops. A Business Impact Analysis (BIA) is a systematic process to determine and evaluate the potential effects of an interruption to critical business operations. It quantifies the financial and operational impact over time, helping to establish recovery objectives such as Recovery Time Objective (RTO) and Recovery Point Objective (RPO). The appropriate action is to implement the corresponding solution, which involves conducting a BIA to identify critical processes and their associated losses.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: MTTR: response/repair time; MTBF: reliability....

✅ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): MTTR: response/repair time; MTBF: reliability. MTTR (Mean Time to Repair) measures the average time to restore a system after a failure, while MTBF (Mean Time Between Failures) indicates the average time between failures, reflecting system reliability.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: 'evaluates impact of losing critical process' = BIA.

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): 'evaluates impact of losing critical process' = BIA. A Business Impact Analysis (BIA) is a systematic process to determine and evaluate the potential effects of an interruption to critical business operations as a result of a disaster, accident, or emergency.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: 'company calculates how much it would lose immediately if e-commerce went down' = BIA....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Business Impact Analysis): 'company calculates how much it would lose immediately if e-commerce went down' = BIA. A Business Impact Analysis (BIA) identifies critical business functions and quantifies the impact of their disruption, including financial loss. This matches the scenario.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* This destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.